Defense:
Prevent, Mitigate, Respond & Test

Taller de Seguridad

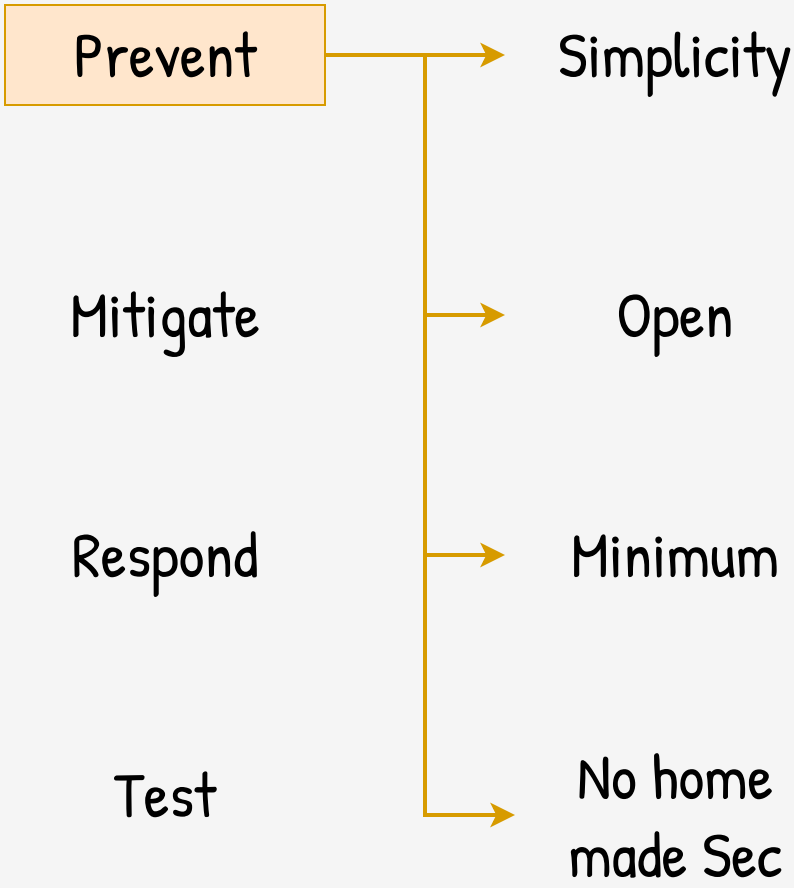
Ing. Martin Di Paola - Fiuba

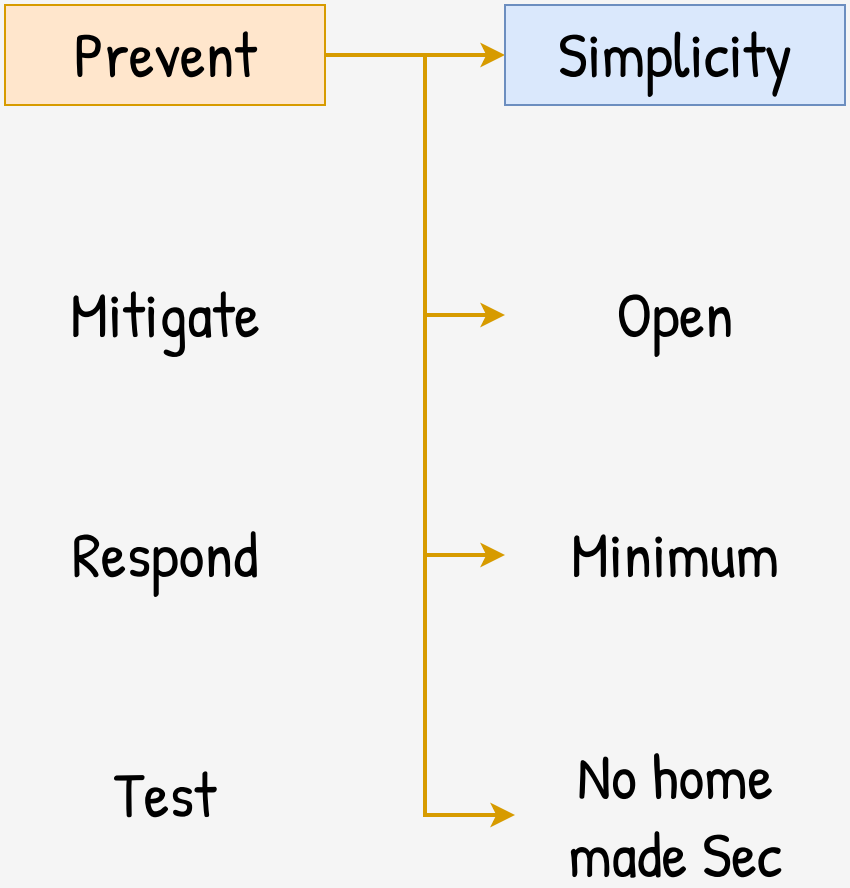
Prevent

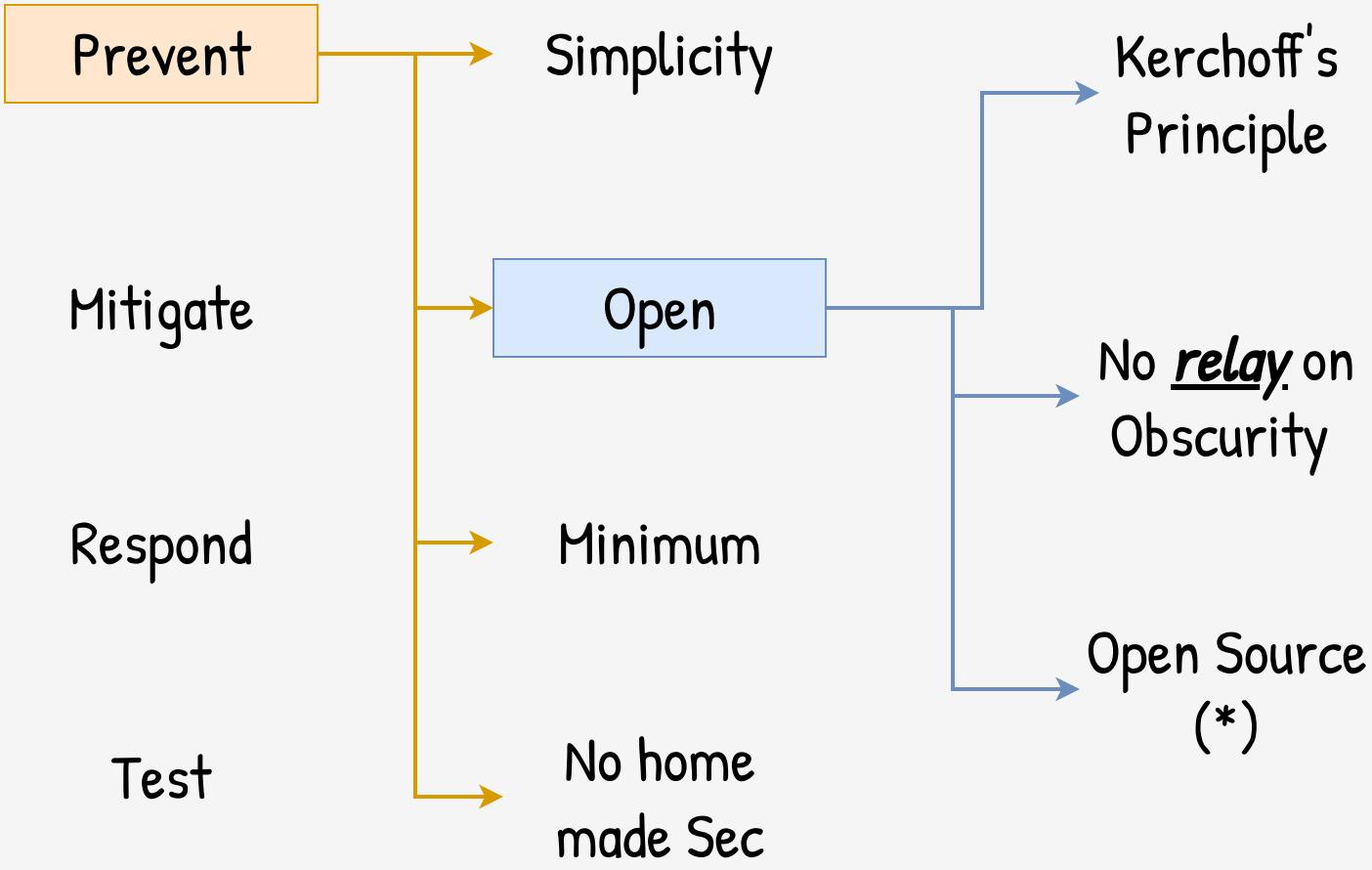
Mitigate

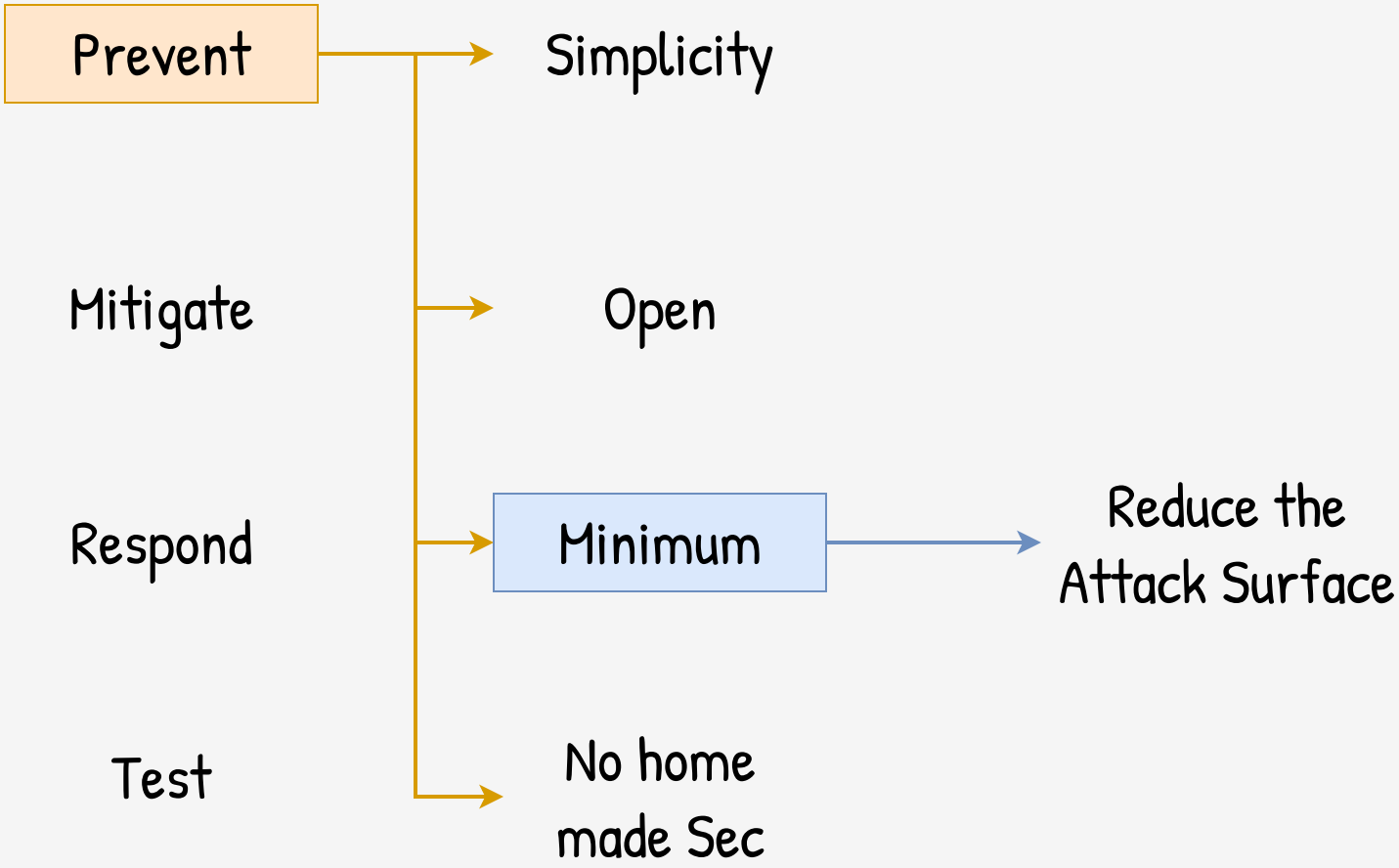
Respond

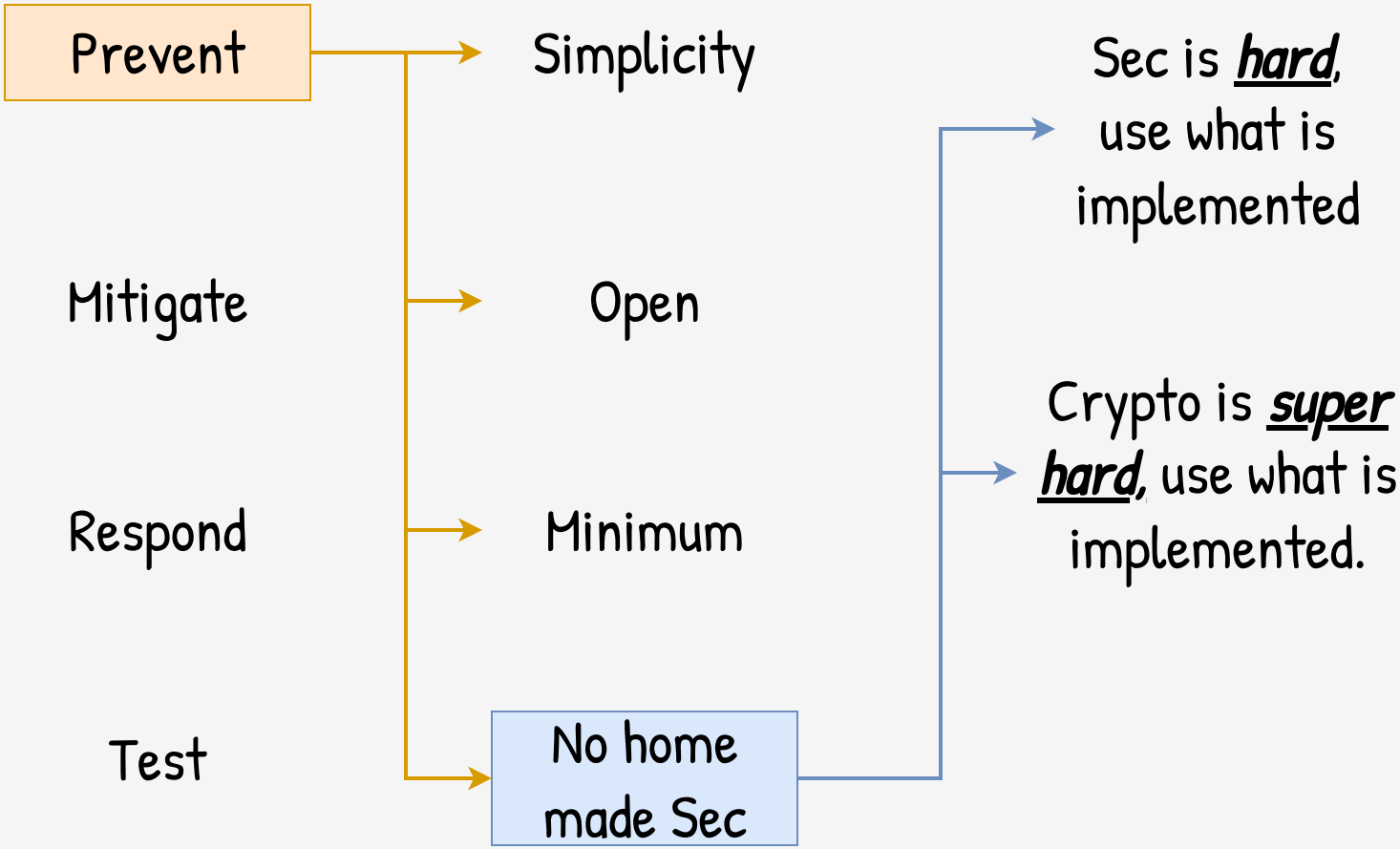
Test

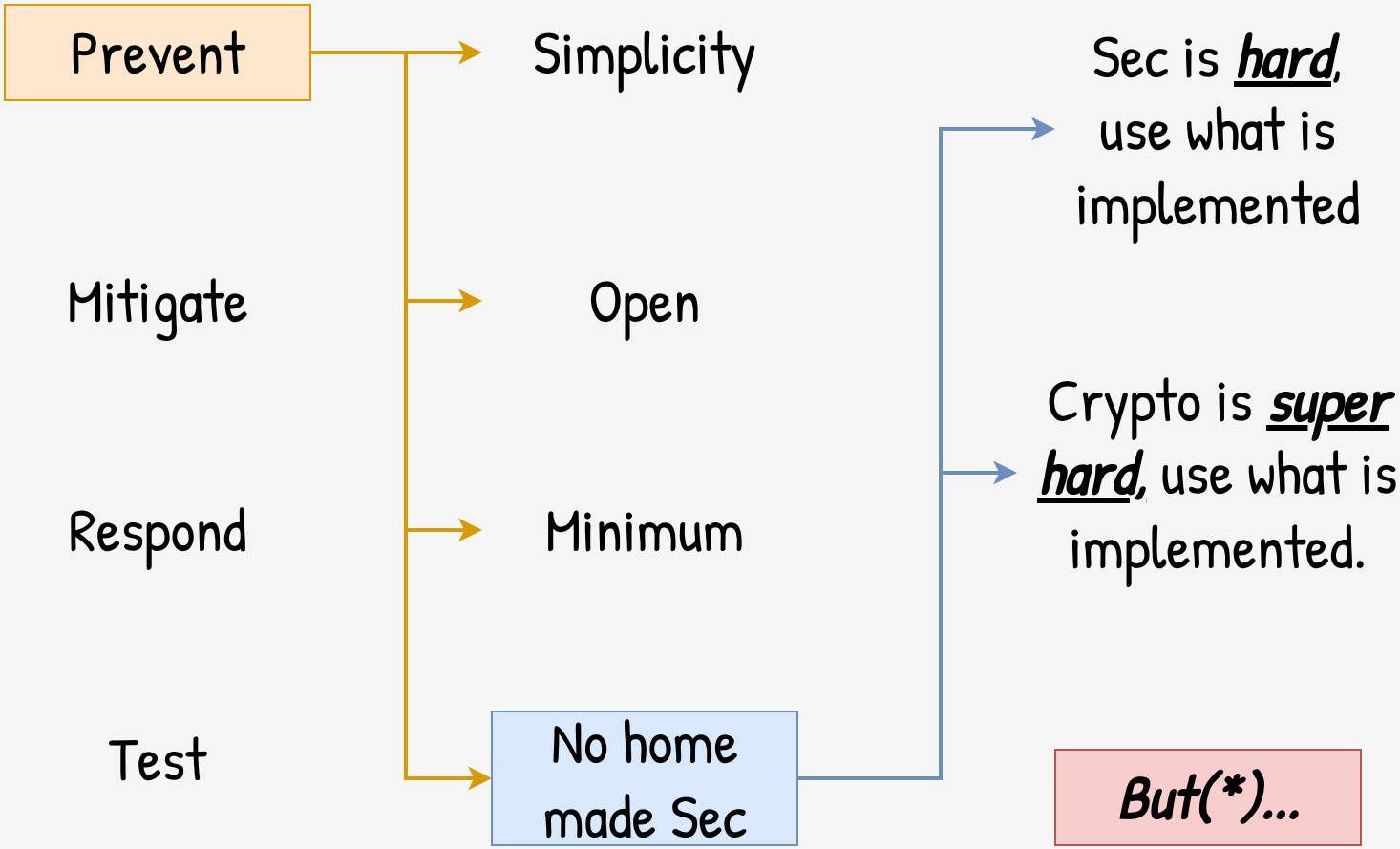

Prevent
Mitigate
Respond
Test
Simplicity
Open
Minimum
No home made Sec

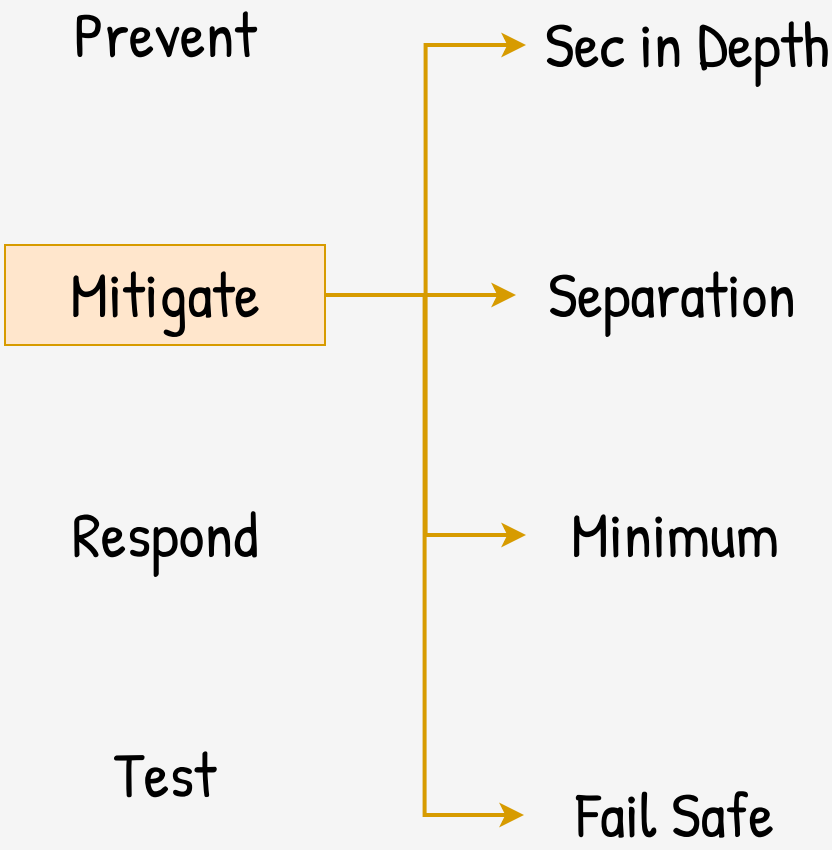

Prevent
Simplicity
Mitigate
Open
Respond
Minimum
Test
No home made Sec

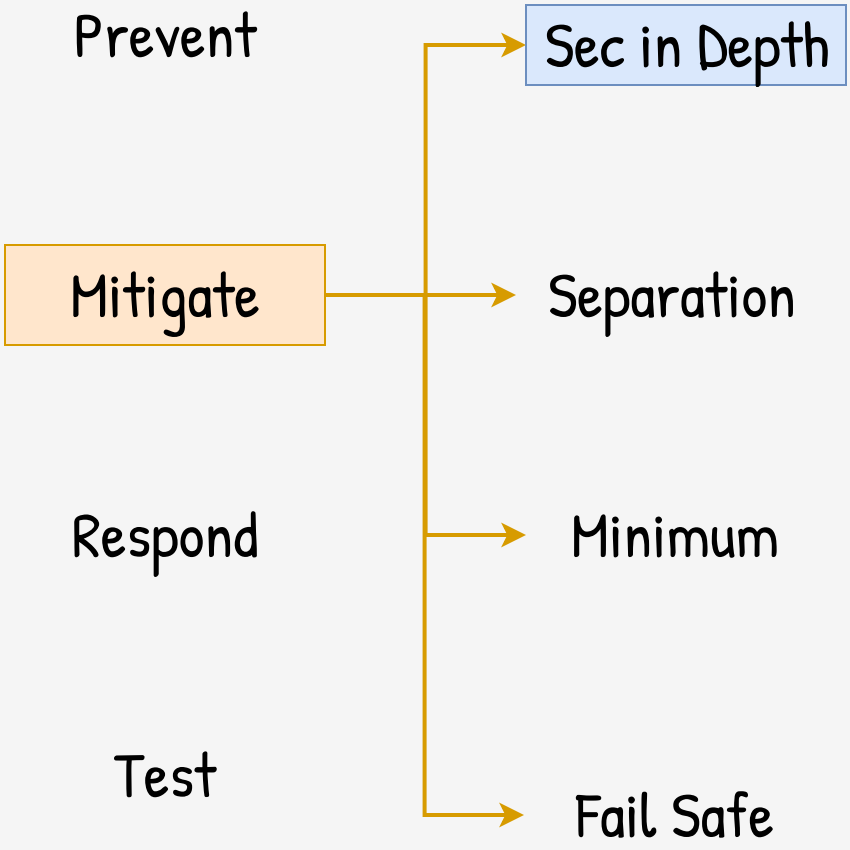

Prevent
Mitigate
Respond
Test
Simplicity
Open
Minimum
No home made Sec
Kerchoff's Principle
No relay on Obscurity
Open Source (*)

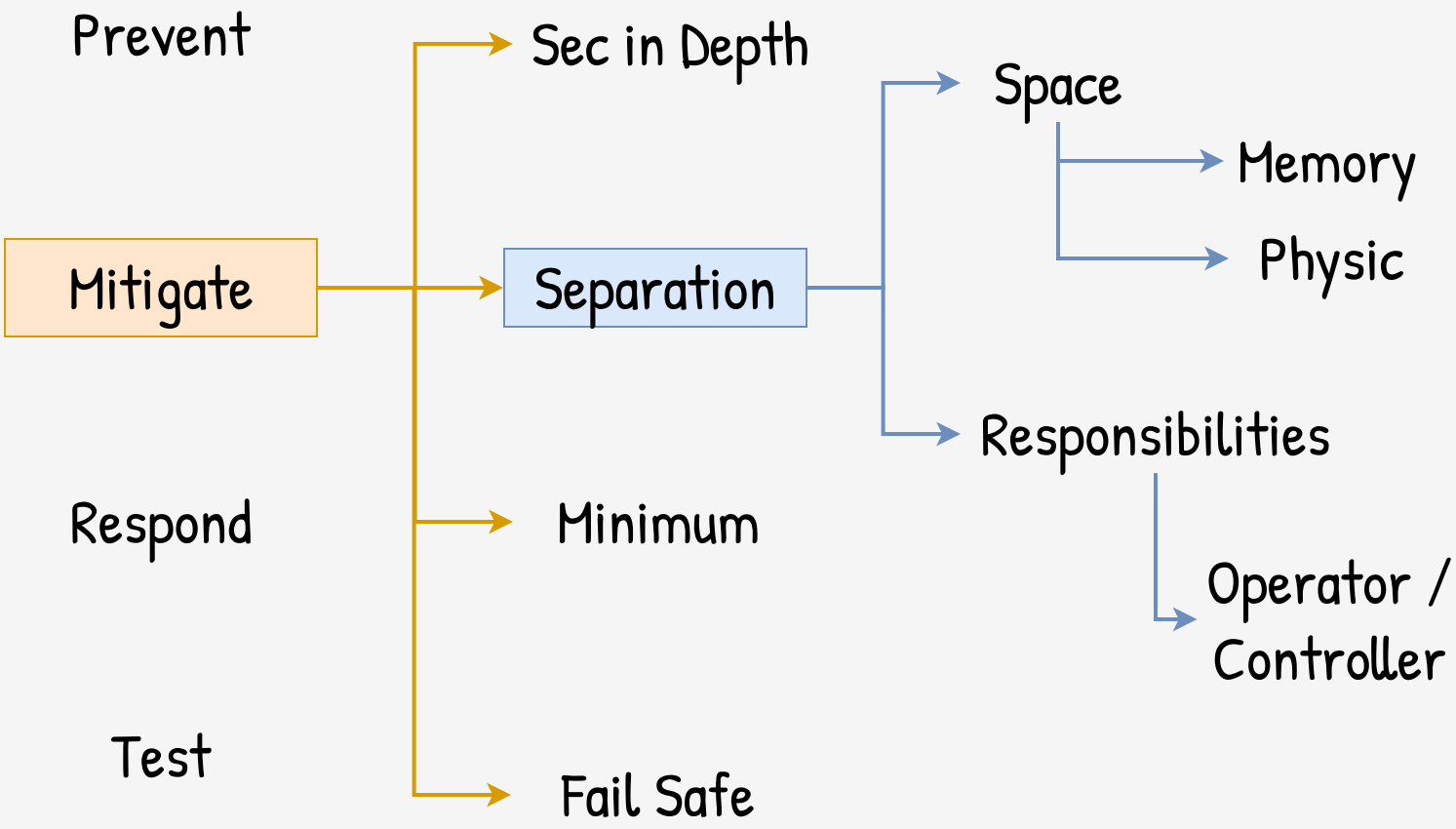

Prevent
Simplicity
Mitigate
Open
Respond
Minimum
Reduce the Attack Surface
Test
No home made Sec

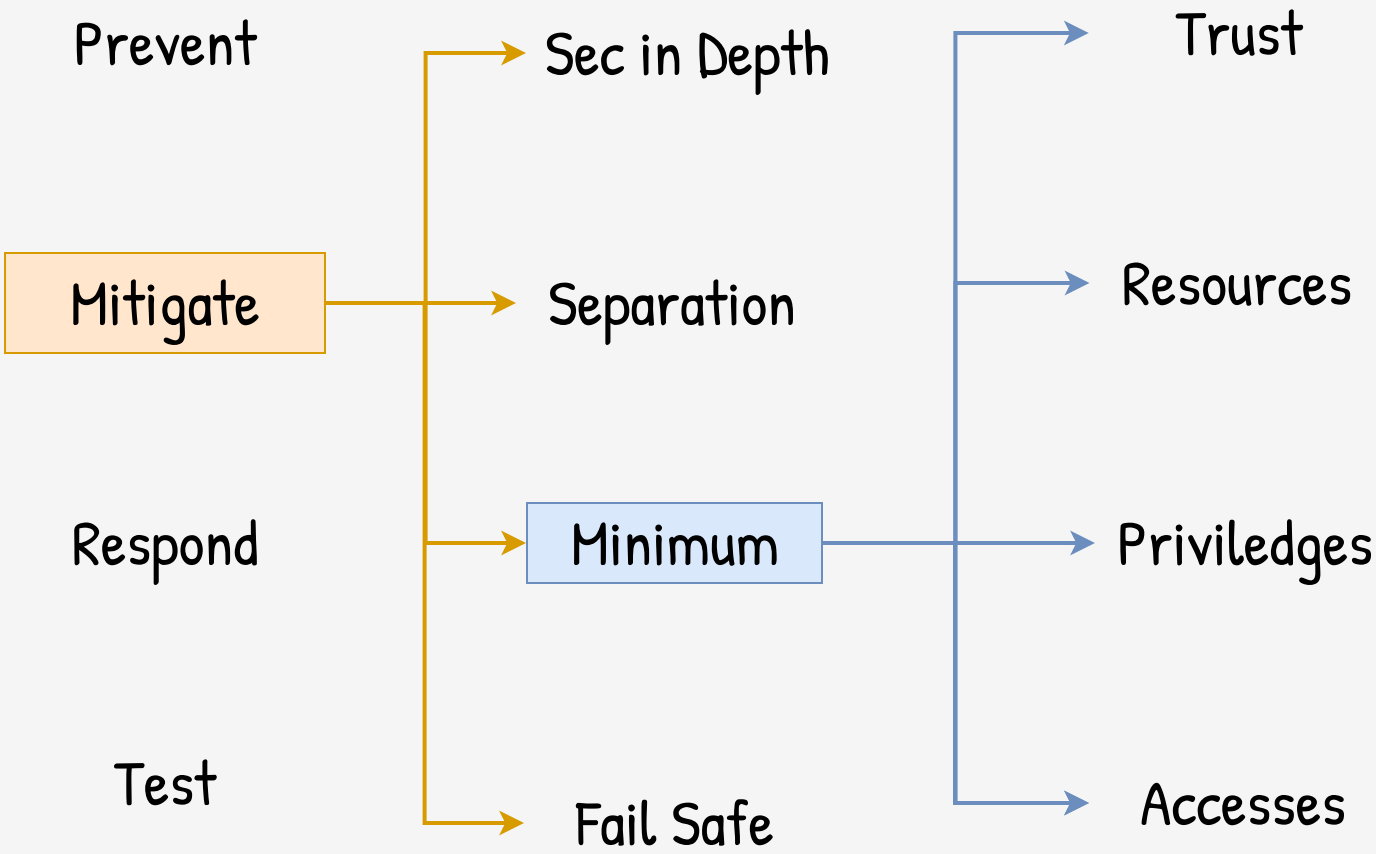

Prevent
Mitigate
Respond
Test
Simplicity
Open
Minimum
No home made Sec
Sec is hard, use what is implemented
Crypto is super hard, use what is implemented.

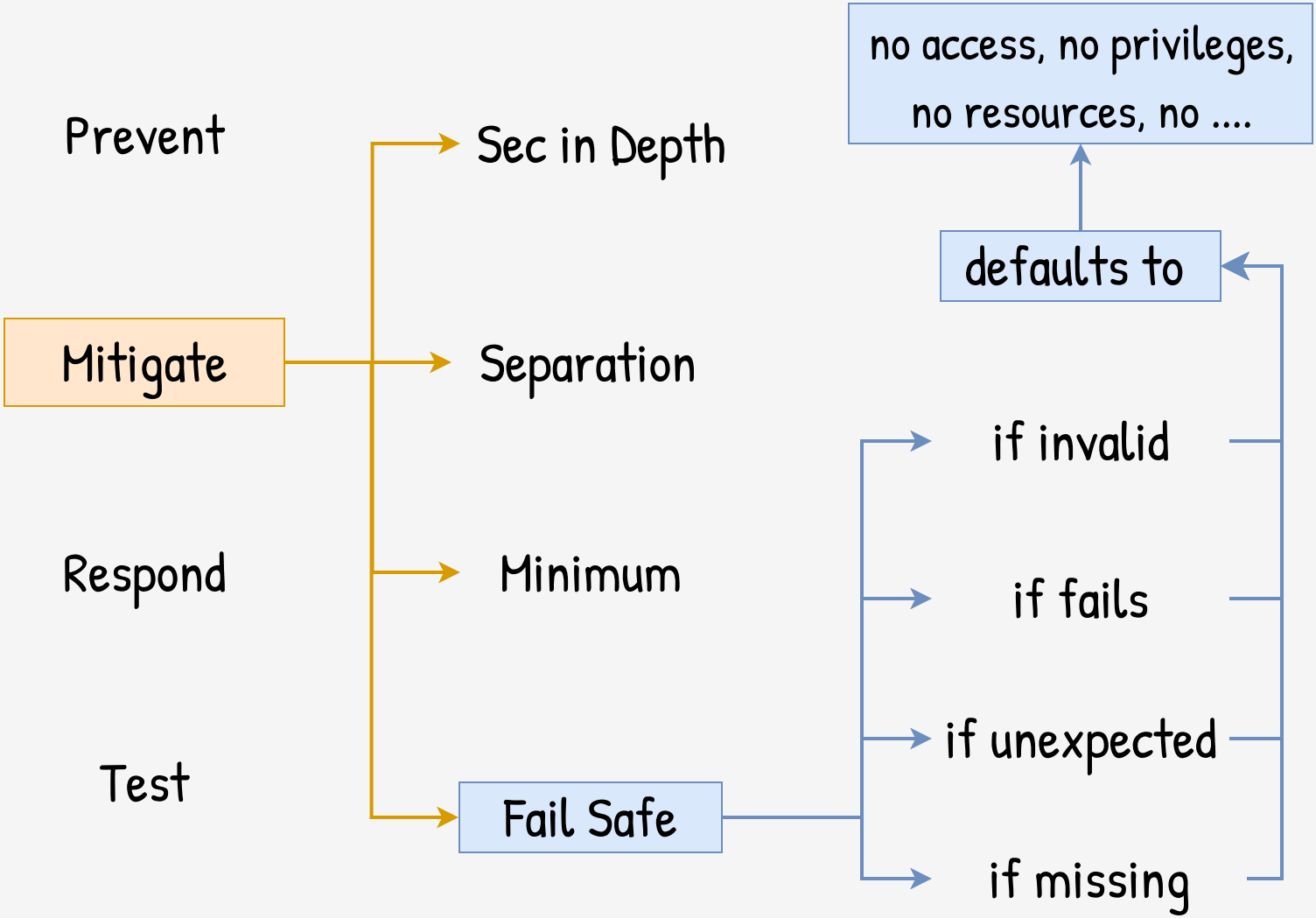

Prevent
Mitigate
Respond
Test
Simplicity
Open
Minimum
No home made Sec
Sec is hard, use what is implemented
Crypto is super hard, use what is implemented.
But(*)...

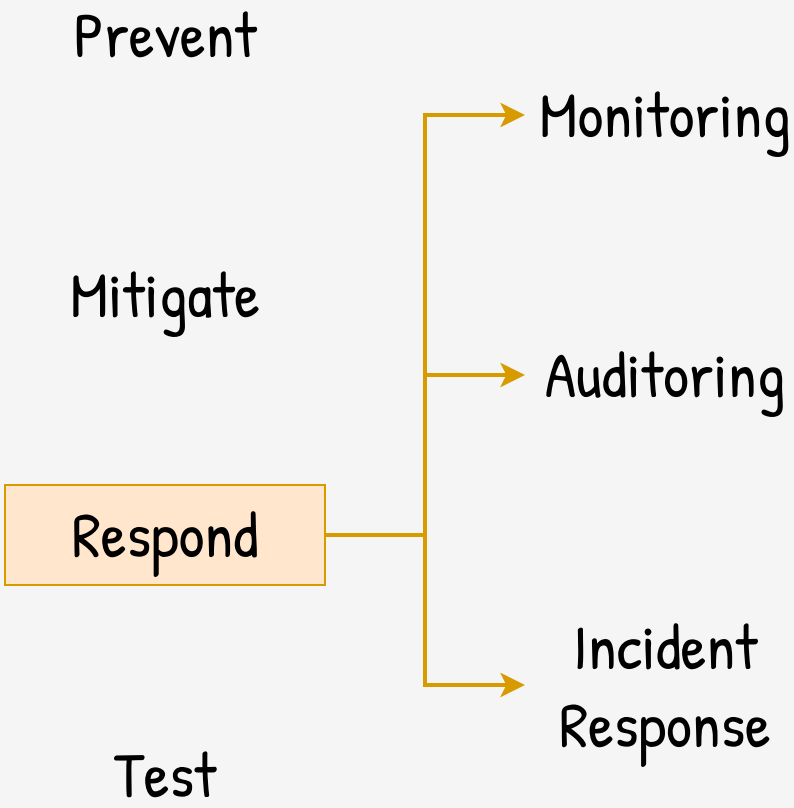

Prevent
Mitigate
Respond
Test
Sec in Depth
Separation
Minimum
Fail Safe

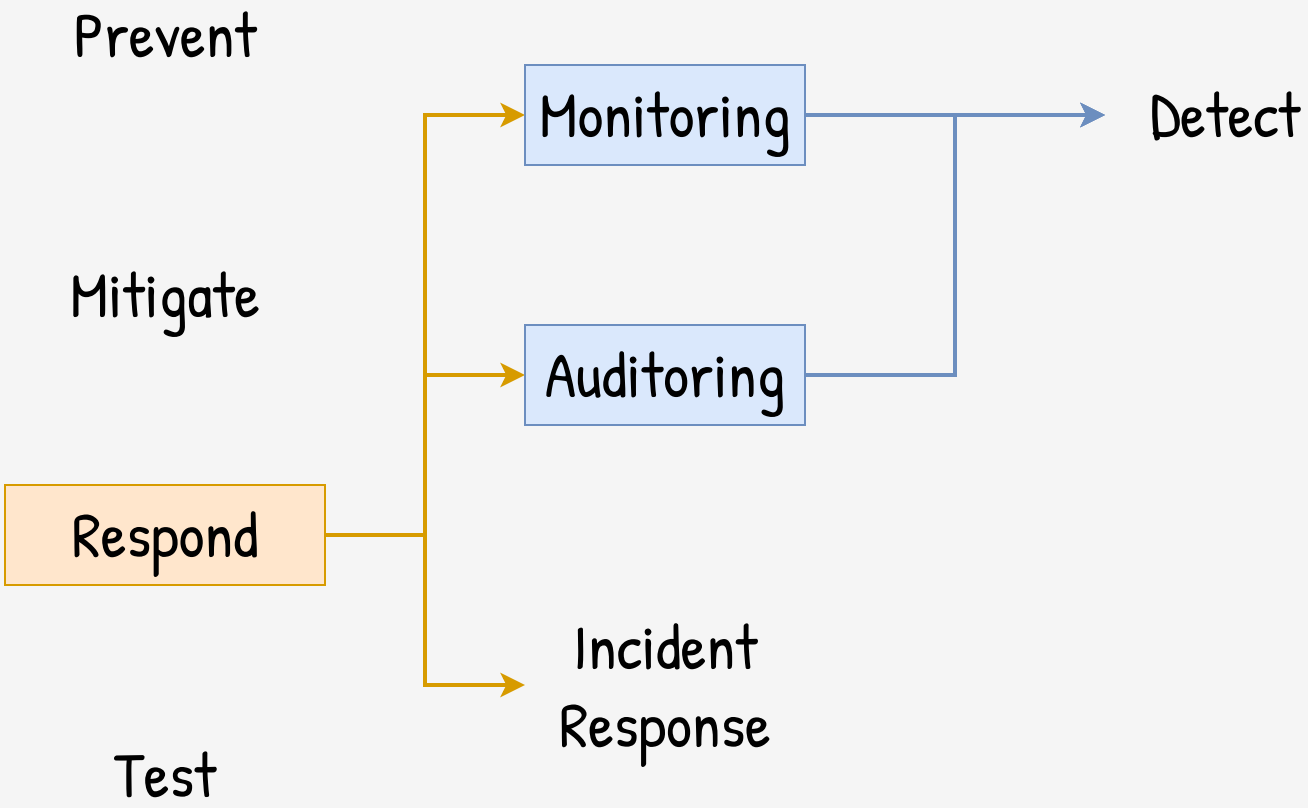

Prevent
Mitigate
Respond
Test
Sec in Depth
Separation
Minimum
Fail Safe

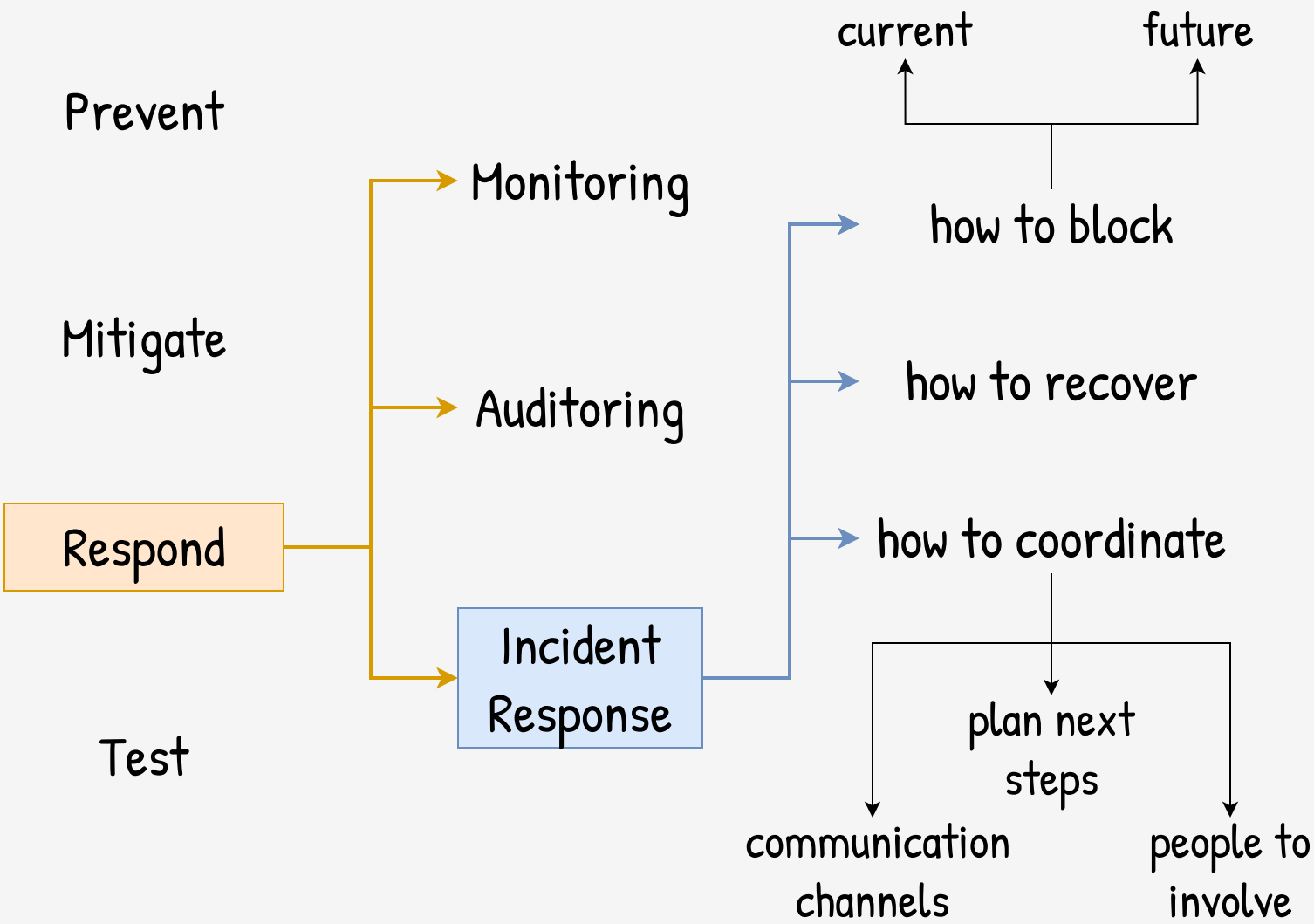

Prevent
Mitigate
Respond
Test
Sec in Depth
Separation
Minimum
Fail Safe
Space
Memory
Physic
Responsibilities
Operator / Controller


Prevent
Mitigate
Respond
Test
Sec in Depth
Separation
Minimum
Fail Safe
Trust
Resources
Priviledges
Accesses


Prevent
Mitigate
Respond
Test
Sec in Depth
Separation
Minimum
Fail Safe
no access, no privileges, no resources, no ....
defaults to
if invalid
if fails
if unexpected
if missing


Prevent
Mitigate
Respond
Test
Monitoring
Auditoring
Incident Response

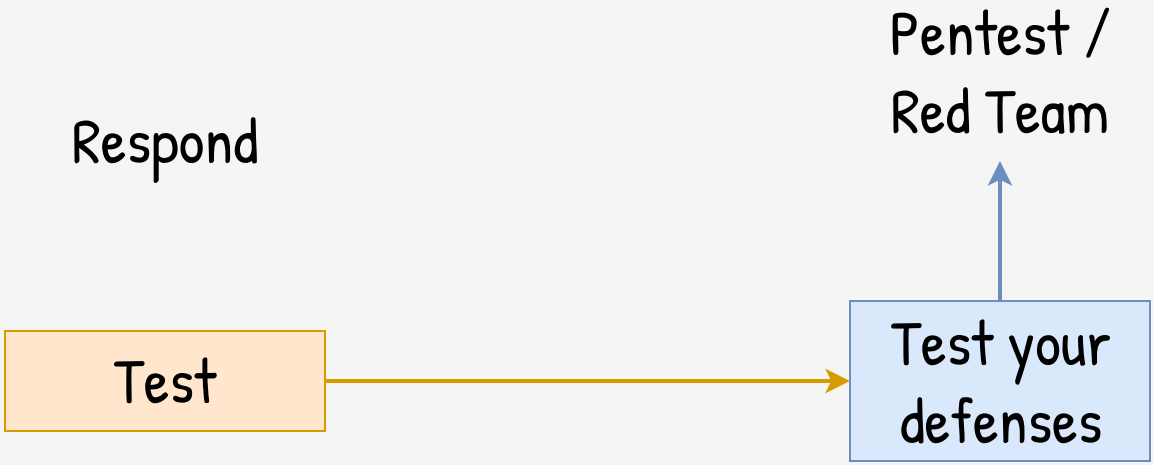

Prevent
Mitigate
Respond
Test
Monitoring
Auditoring
Incident
Response
Detect


Prevent
Mitigate
Respond
Test
Monitoring
Auditoring
Incident Response
how to block
how to recover
how to coordinate
current
future
plan next steps
communication channels
people to involve

Prevent

Mitigate

Respond



Barings Bank
1762 - 1995 (264 years)

Nick Leeson

Trading Manager

Supervisor

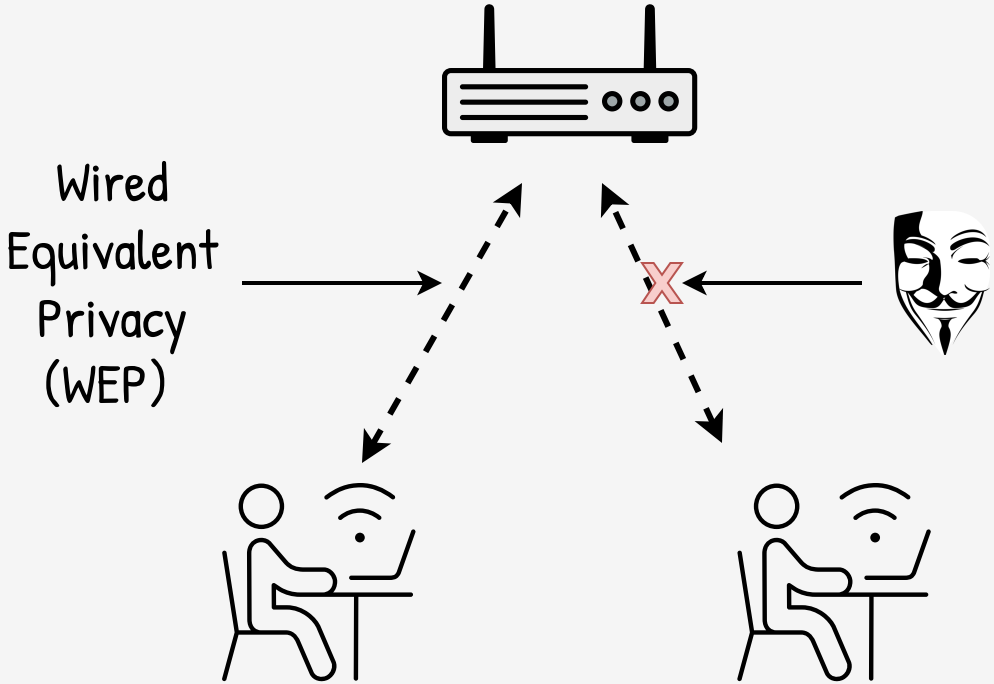
2 roles in 1 person

no separation

no minimum

no monitoring

adidas


Wired
Equivalent
Privacy
(WEP)

WEP 1997

(closed-ish) (impl)

WEP 1997 xx-2001

(closed-ish) (impl) (RC4 confirmed)

WEP 1997 xx-2001

(closed-ish) (impl) (RC4 confirmed)

RC4 1987 1994 (bias found)

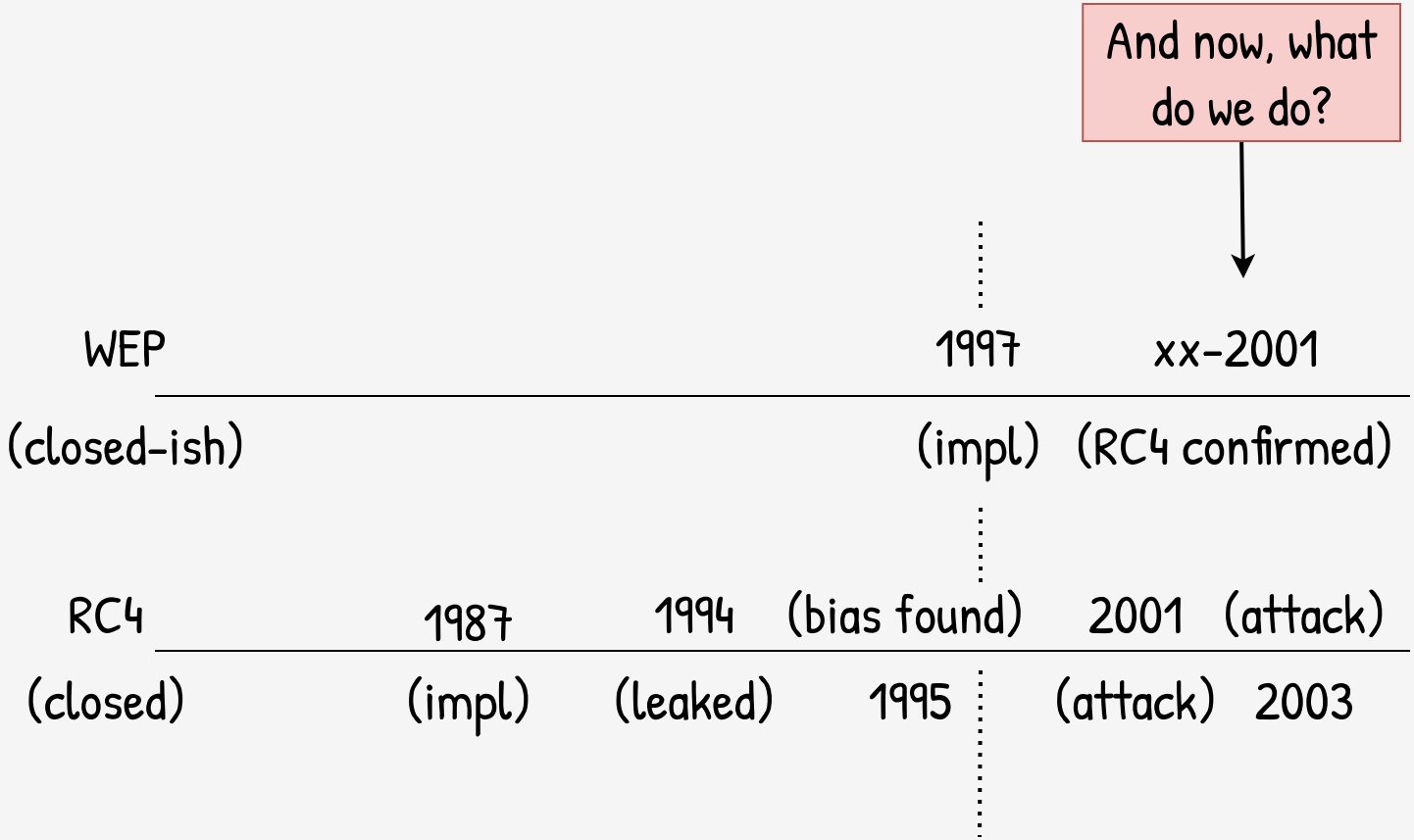
(closed) (impl) (leaked) 1995

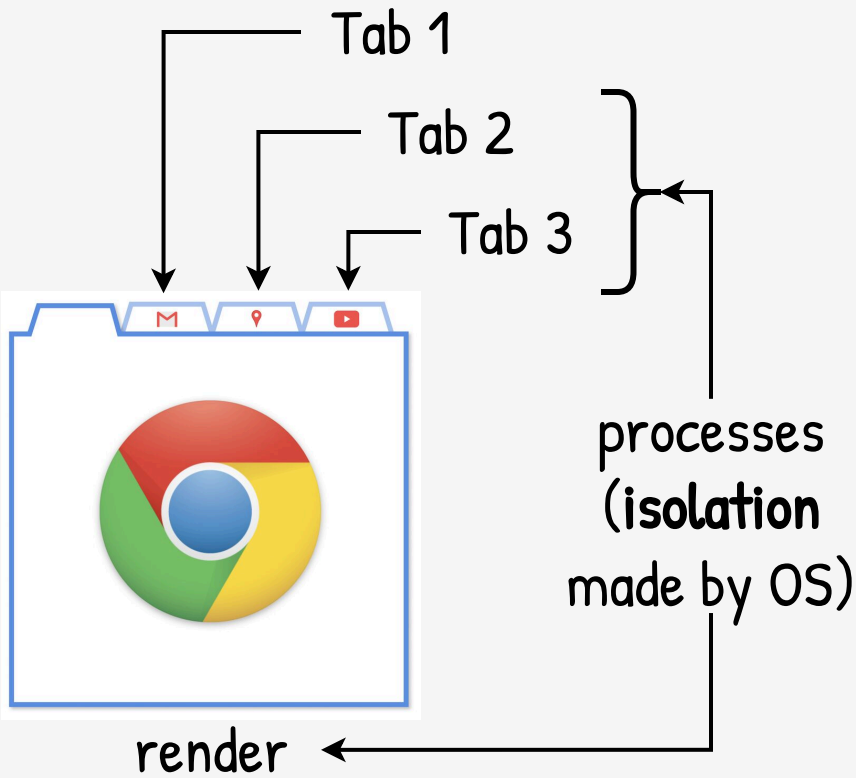
WEP 1997 xx-2001

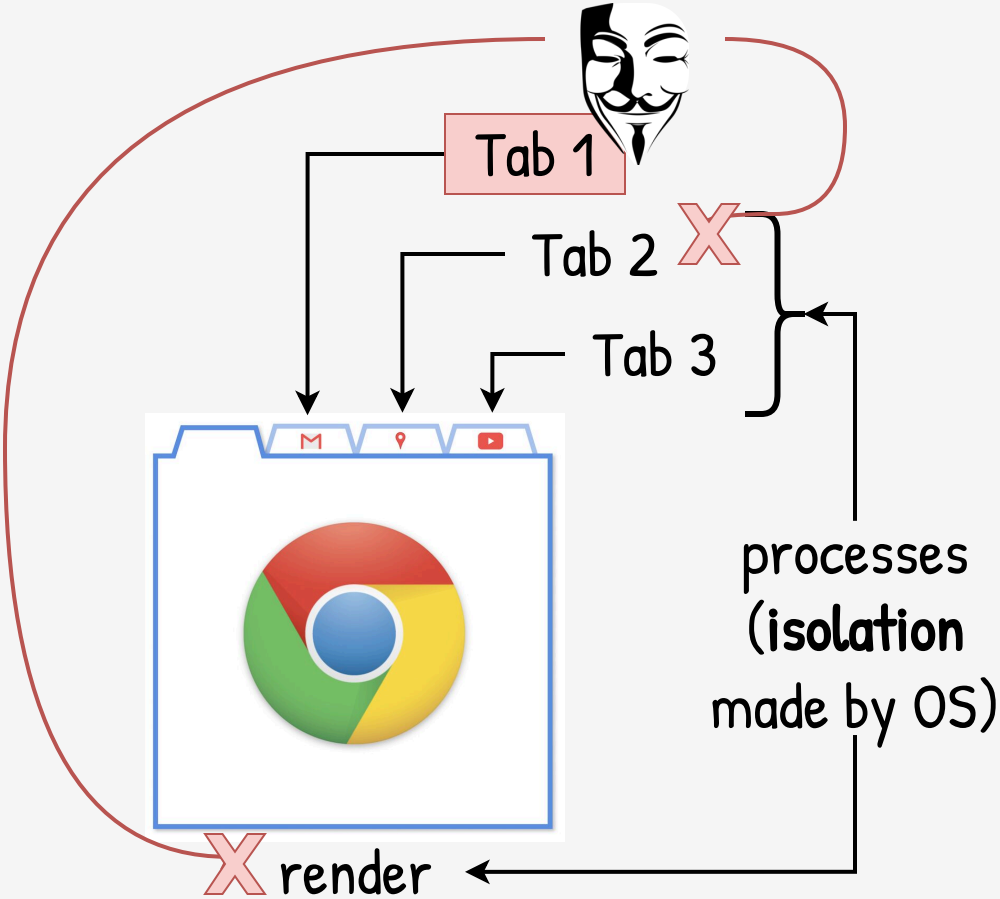
(closed-ish) (impl) (RC4 confirmed)

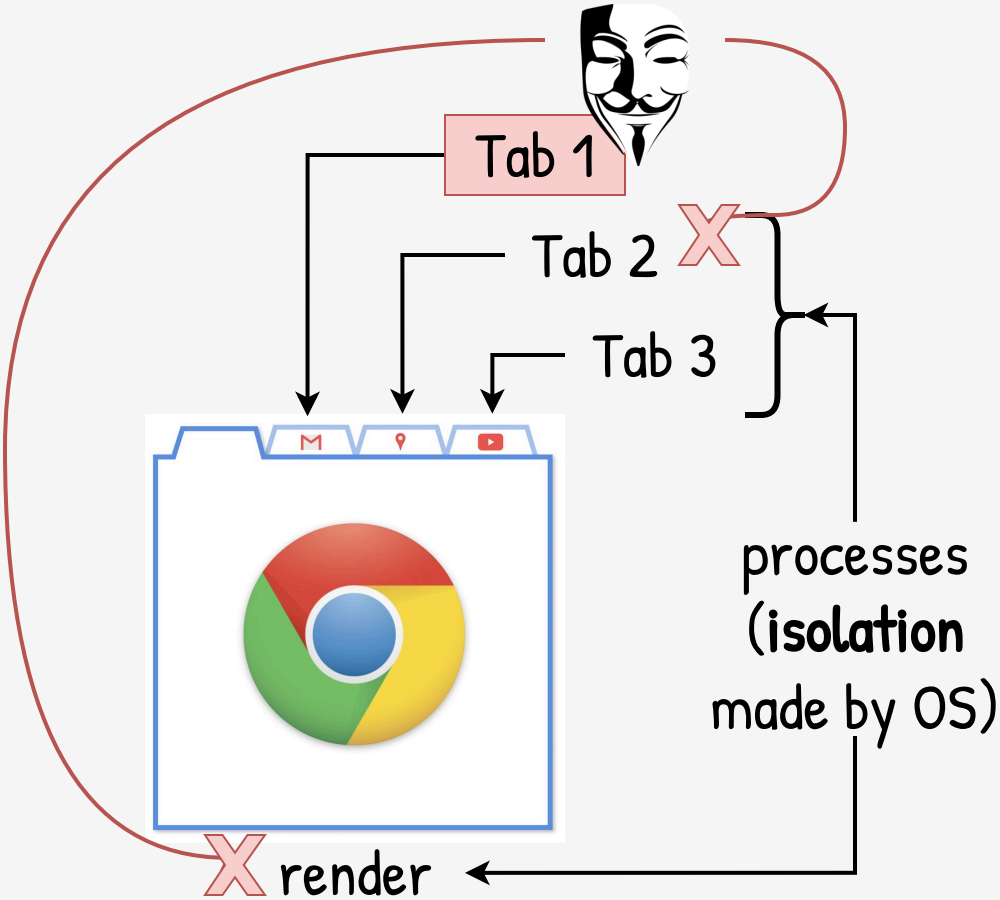
RC4 1987 1994 (bias found) 2001 (attack)

(closed) (impl) (leaked) 1995 (attack) 2003


And now, what do we do?
WEP
1997
xx-2001
(closed-ish)
(impl)
(RC4 confirmed)
RC4
1987
1994
(bias found)
2001
(attack)
(closed)
(impl)
(leaked)
1995
(attack)
2003


Tab 1
Tab 2
Tab 3
processes
(isolation
made by OS)
render


Tab 1
Tab 2
Tab 3
processes
(isolation
made by OS)
render



Isolation

Processes

↓

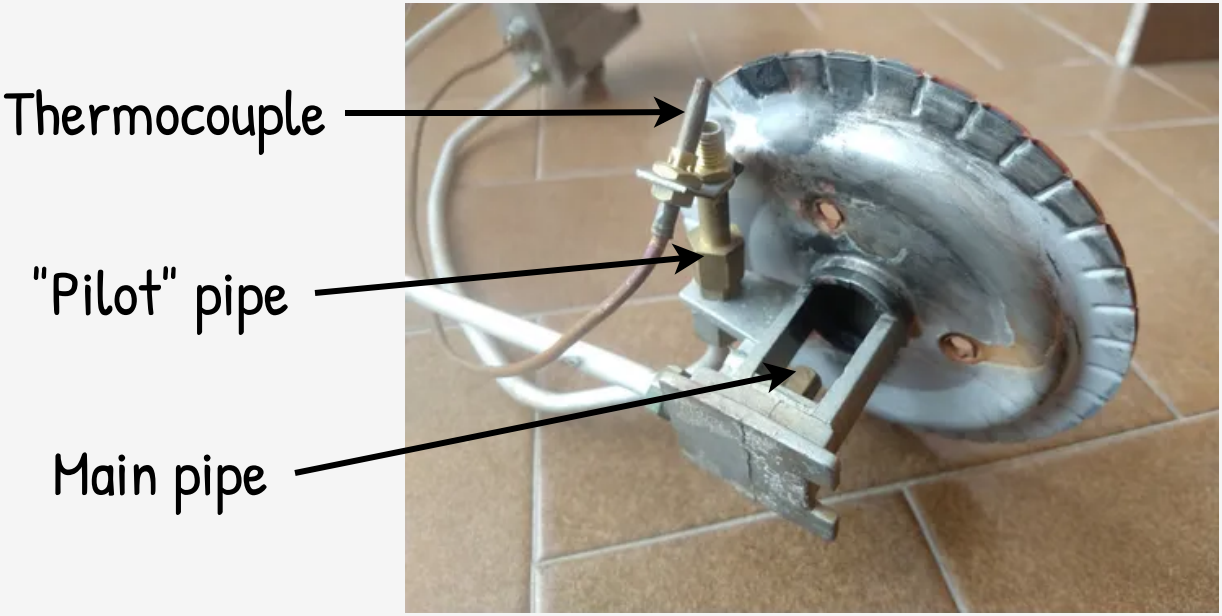
Containers

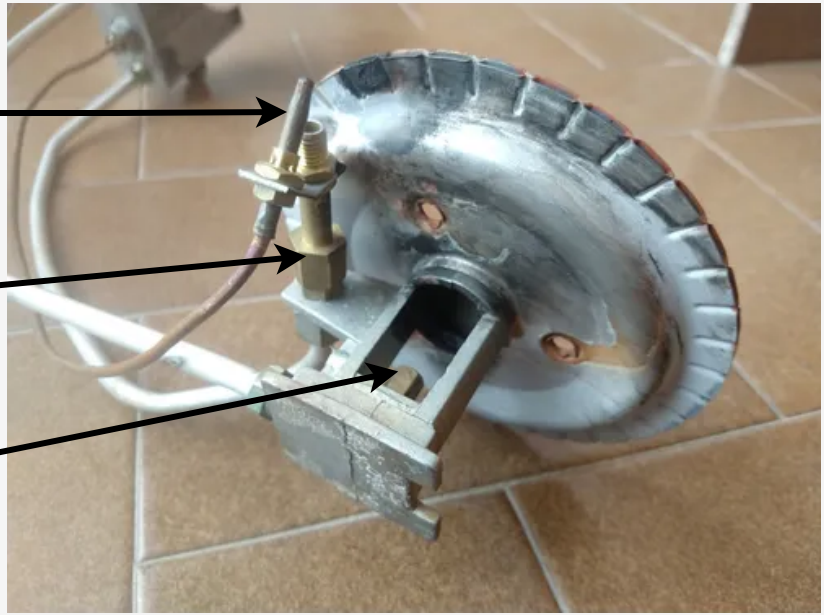
↓

Virtual Machines

↓

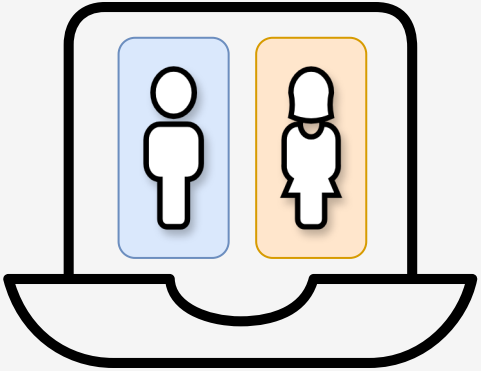
Physical Machines


Thermocouple
"Pilot" pipe
Main pipe

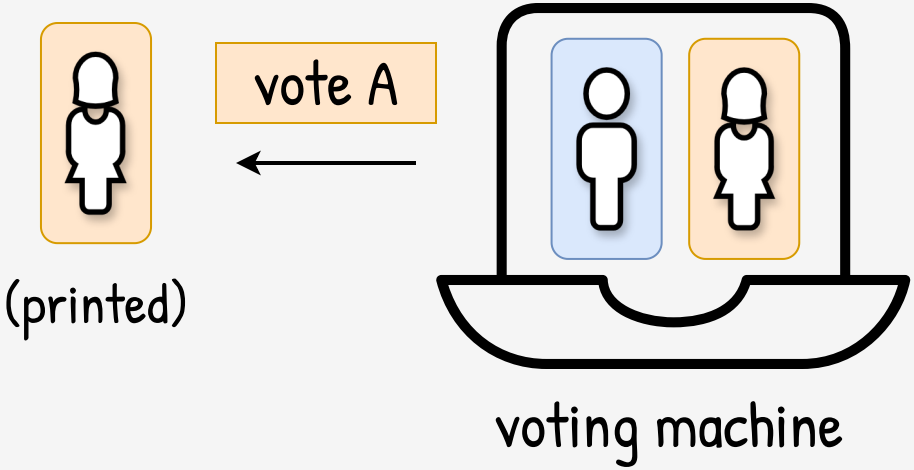


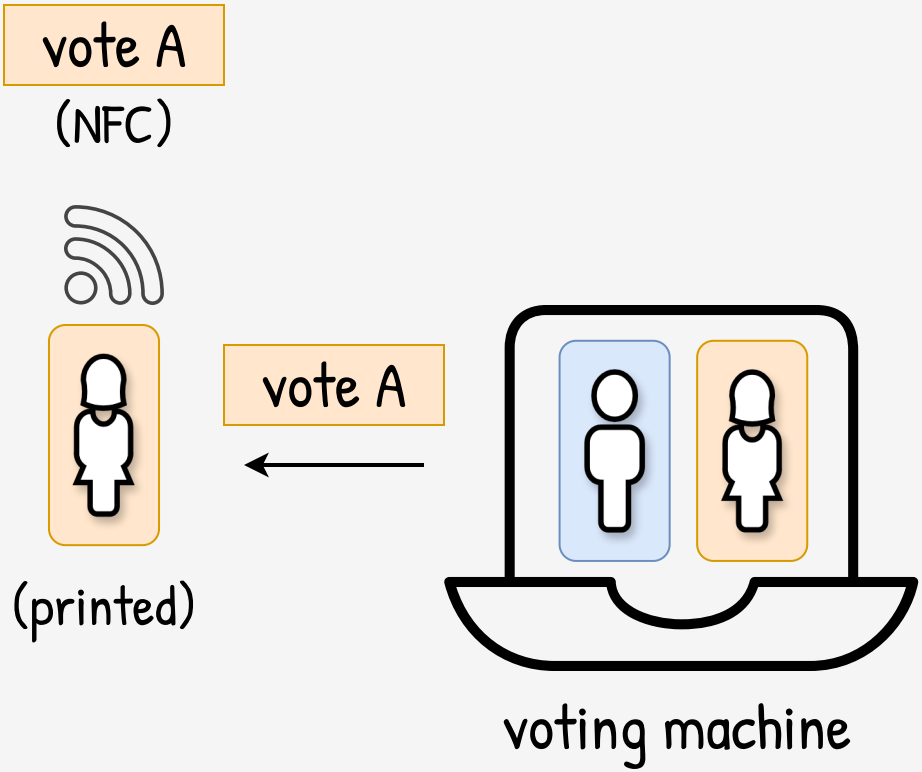
Simple

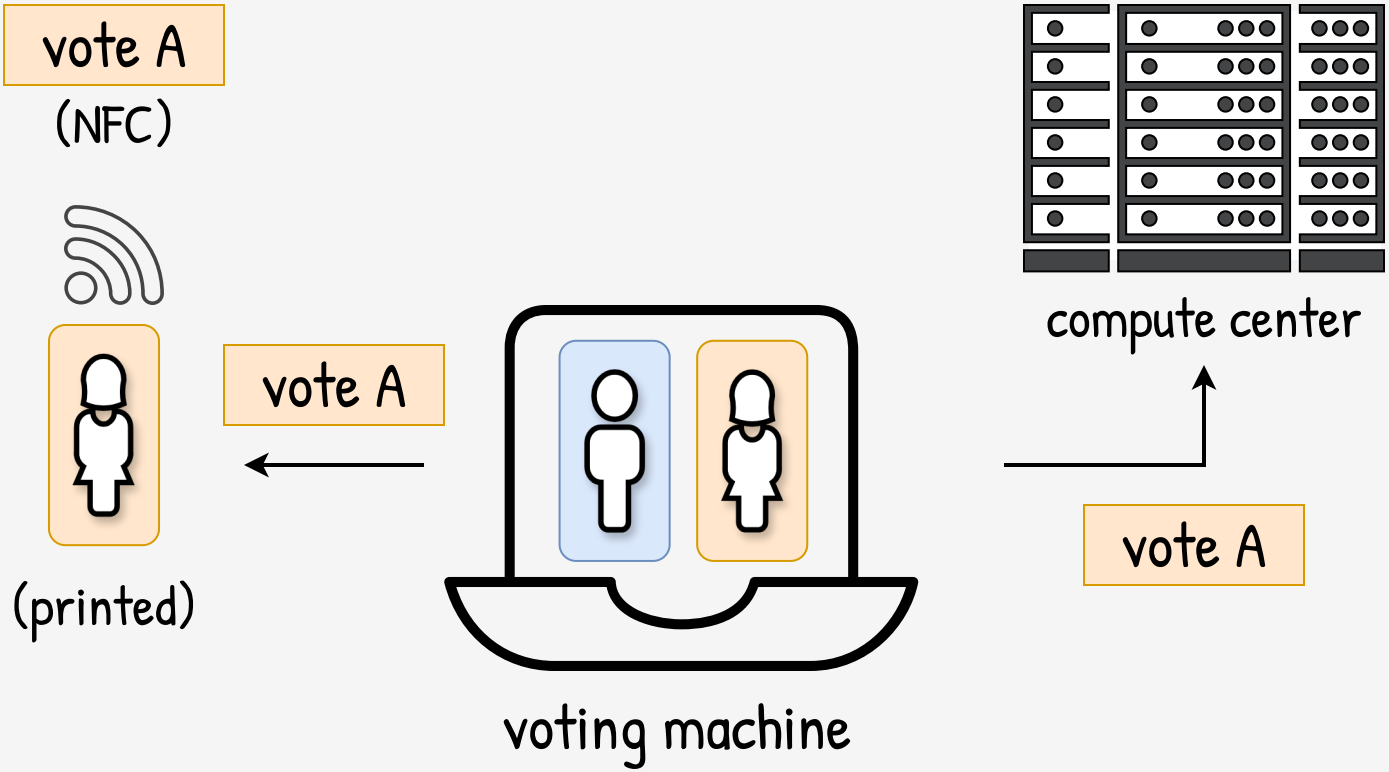
Fail Safe

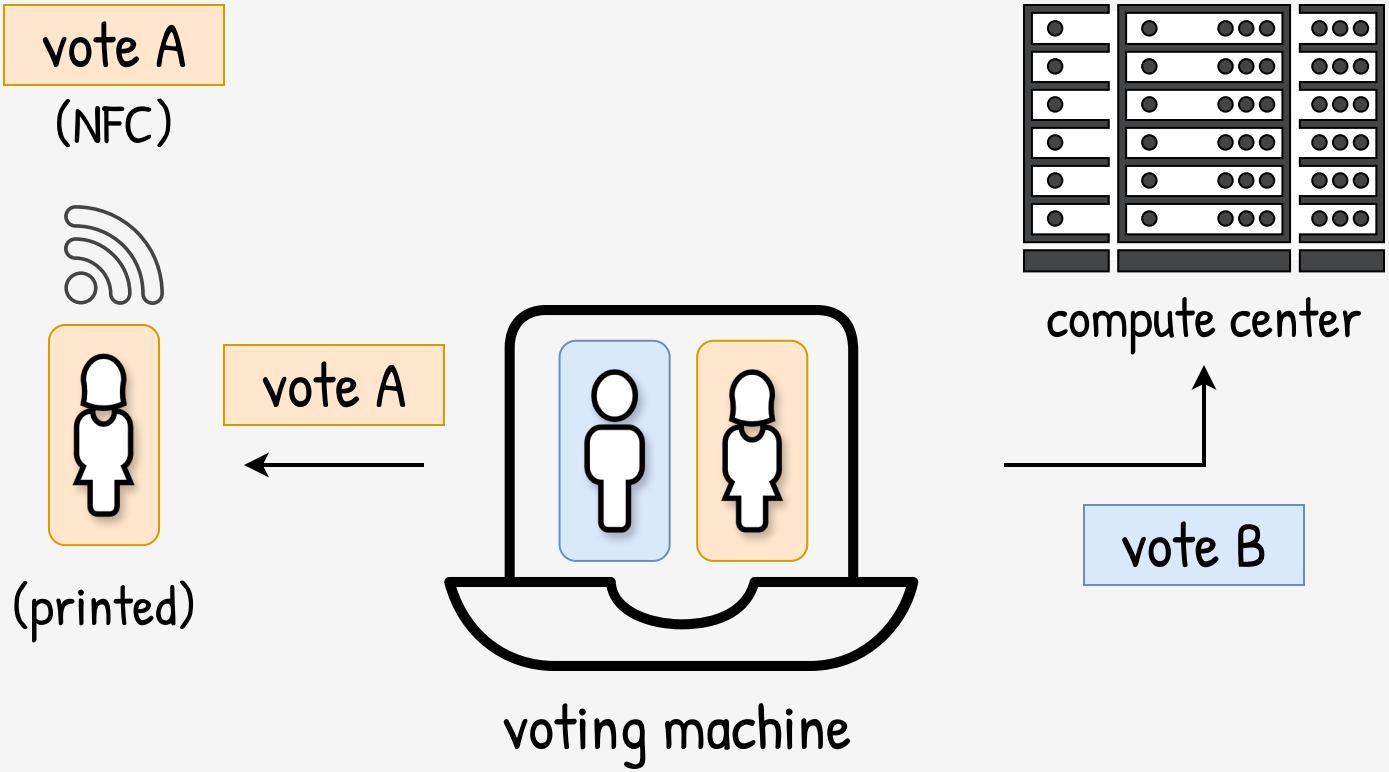


voting machine


vote A
(printed)
voting machine


vote A
(NFC)
vote A
(printed)
voting machine

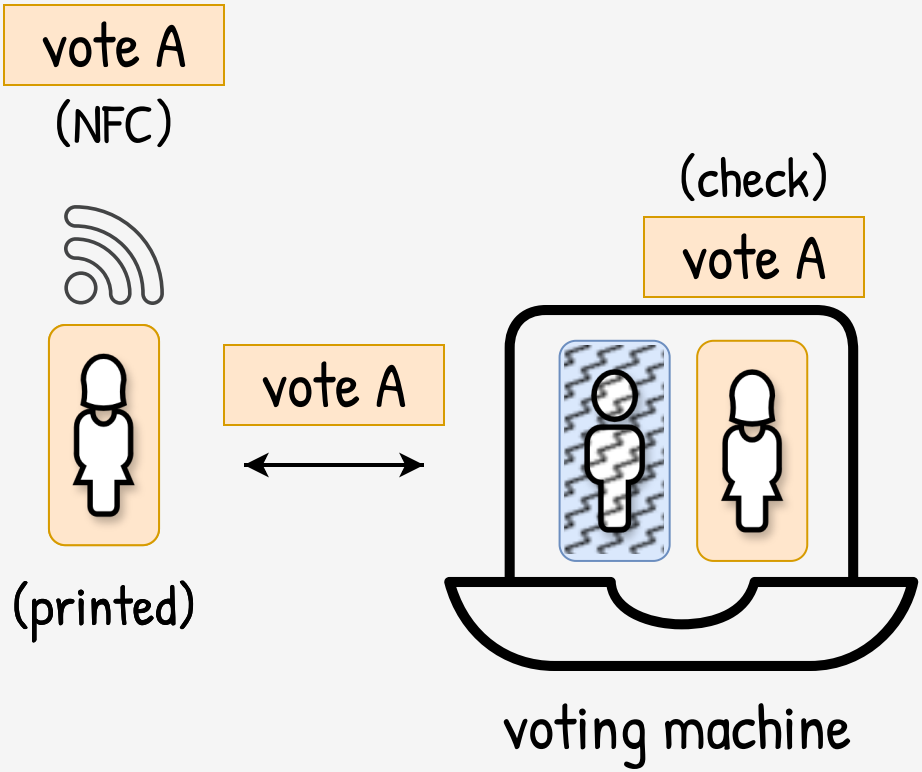

vote A
(NFC)
(printed)
vote A
voting machine
compute center
vote A

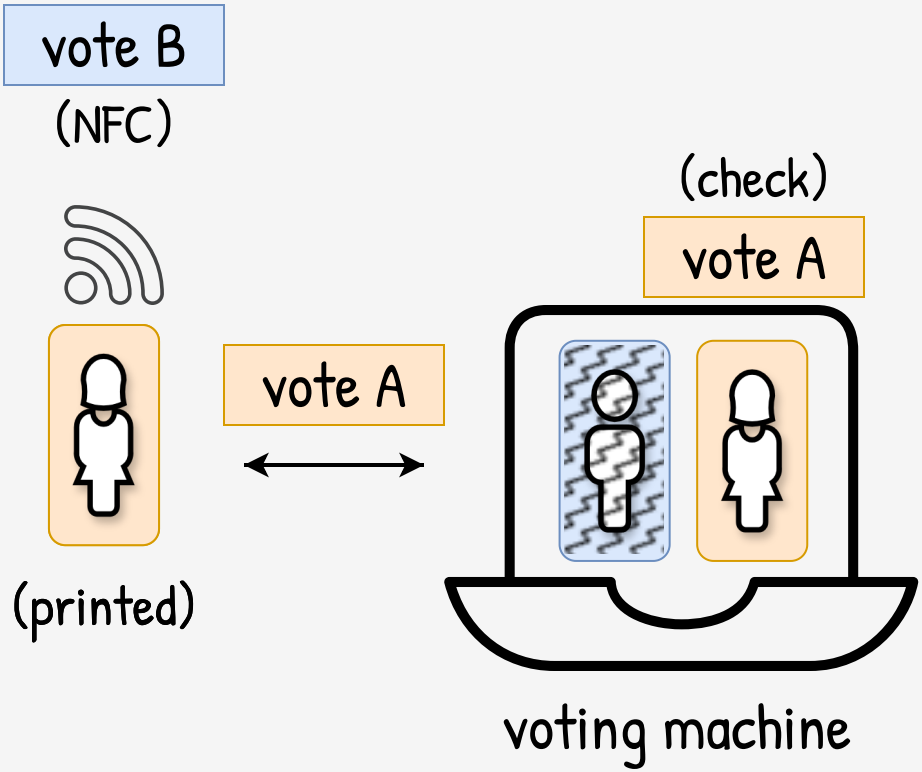


Opaque (not open).

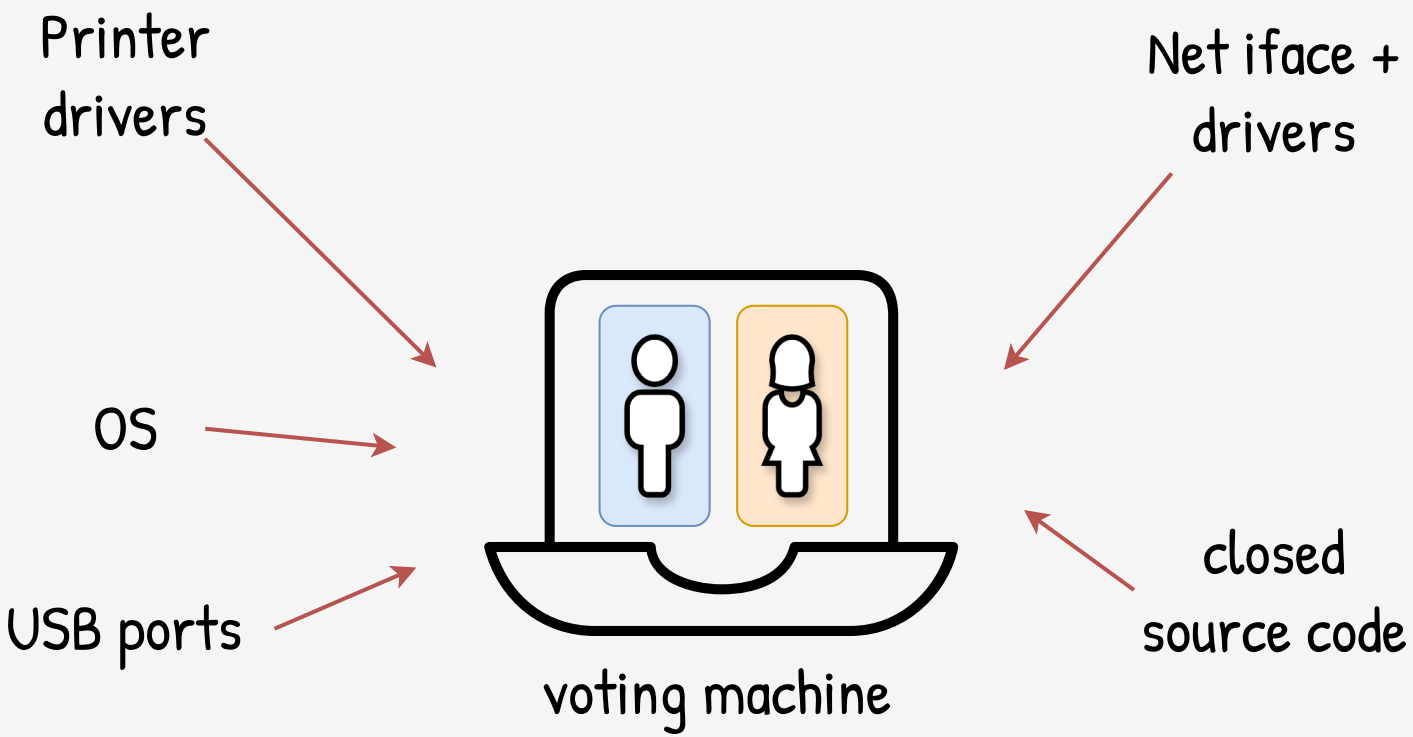
How the voter could ***check***?

How could she ***trust***?

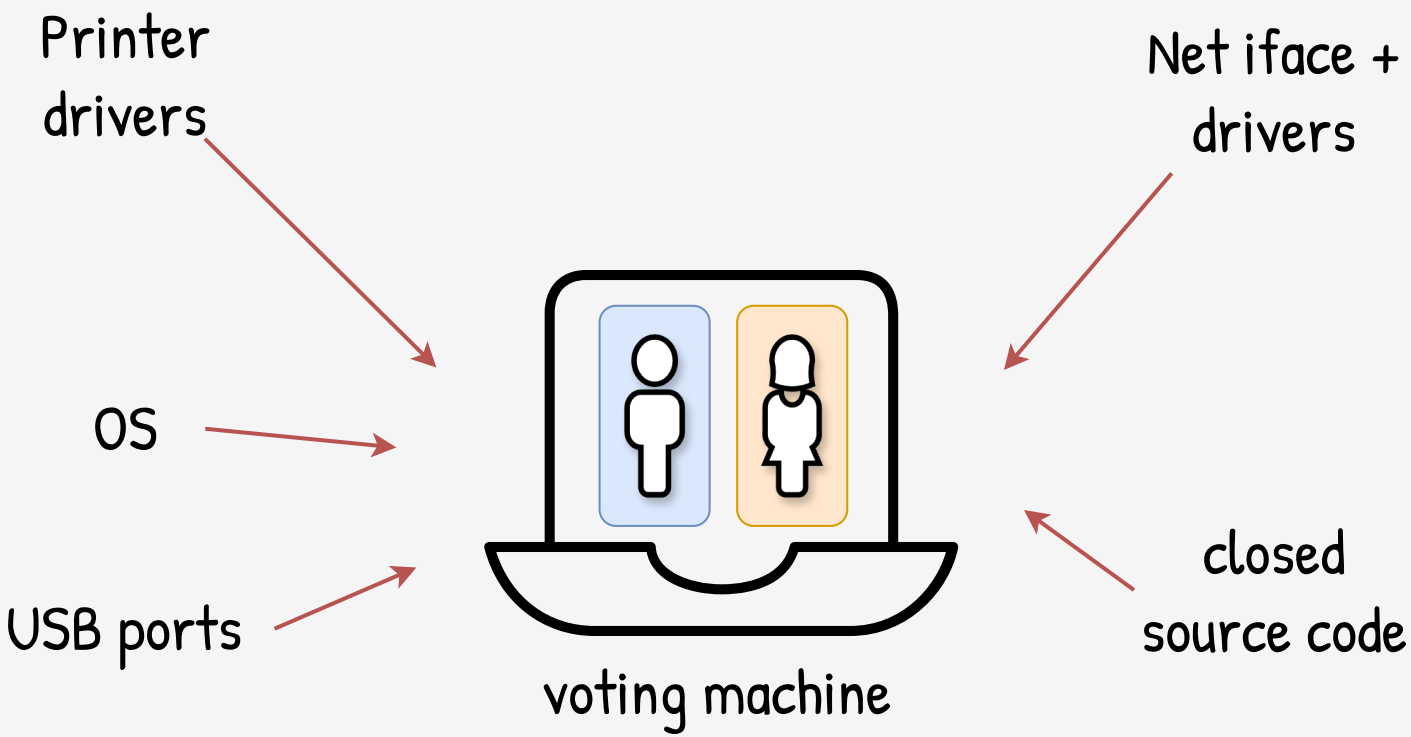

vote A
(NFC)
(printed)
vote A
(check)
vote A
voting machine



Same machine for voting ***and*** for controlling the vote



https://www.youtube.com/watch?v=HwyN6P83HcY



https://www.youtube.com/watch?v=HwyN6P83HcY

Complex (not simple).
How anyone can ***verify*** that the machine ***work as it should***?